Cibersegurança - Segurança em Software (Módulo 2)

Trabalho Prático - Parte 1

Esta tarefa consiste em explorar a vulnerabilidade shellshock num ambiente controlado.
Entrega:

- Documento com evidências e explicações solicitadas em cada questão. A entrega será feita juntamente com a parte 2 da parte prática.

1. Enquadramento

Considere que durante uma auditoria de segurança à empresa fictícia *SecureTech*, foi identificado um servidor web Apache legado a correr numa máquina Linux. Suspeita-se que este servidor esteja vulnerável à falha **Shellshock (CVE-2014-6271)** devido ao uso de scripts CGI antigos baseados em *bash*.

Pretende-se simular um teste de penetração de forma segura sem colocar em risco a infraestrutura de produção. A equipa de TI da SecureTech disponibilizou uma réplica exata e virtualizada do servidor em formato de imagem Docker. Ao executar este contentor no seu computador local, estará a simular o comportamento do servidor HTTP real da empresa.

2. Preparação do ambiente de Simulação

O servidor simulado da *SecureTech* está empacotado na seguinte imagem Docker disponível no DockerHub, `jsimao/cs-shellshock-amd64` (ou `arm64`). O servidor web Apache interno escuta na porta 80, mas no seu computador ficará acessível na porta 8080.

Execute o comando adequado à arquitetura do seu sistema operativo para arrancar o servidor simulado (use a imagem `cs-shellshock-arm64` para sistemas com hardware arm64):

```
docker run -d -p 8080:80 --name shellshock jsimao/cs-shellshock-amd64
```

a) Confirme que o servidor simulado da *SecureTech* está operacional acedendo aos endpoints `http://localhost:8080/cgi-bin/getenv.cgi` e `http://localhost:8080/cgi-bin/vul.cgi` via com o curl, Postman ou browser. Registe os ecrãs com as evidências do pedido e da resposta HTTP recebida.

b) Aceda ao interior do contentor Docker em execução e analise o conteúdo dos dois CI da alínea anterior (ex: `docker exec -it shellshock cat /usr/lib/cgi-bin/vul.cgi`).

Registe o conteúdo de ambos os CGI, e explique o resultado obtido na alínea a) quando fez a chamada ao `getenv.cgi`.

3. Exploração (Red Team)

a) Através do endpoint `/cgi-bin/vul.cgi`, explore a vulnerabilidade Shellshock para extrair o conteúdo do ficheiro `/etc/passwd`[i] do servidor. Note que:
   - a exploração da vulnerabilidade não depende do script que está no `vul.cgi` mas sim no facto do CGI usar o *bash shell* vulnerável
   - é preciso garantir que a resposta recebida no cliente mantém a conformidade com o protocolo HTTP.

b) Crie um ficheiro denominado `evidence_<numero_aluno>.txt` na diretoria `/tmp` contendo a data atual e o seu nome. Registe uma captura de ecrã com a lista deste ficheiro no sistema do contentor.

c) Os pedidos HTTP GET podem enviar dados no URL após a marca '?', na zona designada *query string*. Demonstre que a *query string* aparece também numa variável de ambiente. É possível usar este método para lançar o ataque Shellshock?

4. Análise de permissões

a) Tente aceder ao ficheiro `/etc/shadow`. Explique o resultado obtido com base no utilizador sob o qual o serviço Apache está a ser executado.

[i] https://en.wikipedia.org/wiki/Passwd